

Tra cứu Danh bạ Nhân sự (HR Directory)

Môn học: IAW301 | Chủ đề: Lộ lọt thông tin (Information Disclosure) | Số trang: 1

1. Bối cảnh & Mô tả hệ thống

Hệ thống quản lý nhân sự nội bộ của doanh nghiệp cung cấp API phục vụ ứng dụng Web Portal và Mobile App để nhân viên tìm kiếm thông tin liên hệ và phòng ban của đồng nghiệp trong công ty.

Hệ thống cung cấp các chức năng chính:

- `GET /api/v1/employees/search?keyword= ...`: Tìm kiếm danh bạ nhân viên theo tên hoặc phòng ban.
- `GET /api/v1/employees/{employee_id}`: Xem chi tiết thông tin hồ sơ của một nhân viên.
- Ứng dụng Web và Mobile hiển thị thông tin danh bạ gồm họ tên, email và phòng ban của nhân viên.

2. Nhiệm vụ của sinh viên (Yêu cầu bài thi)

Nghiên cứu mã nguồn trong tệp `main.py` đi kèm và thực hiện các yêu cầu sau:

Câu 1: Phân tích vấn đề trong thiết kế hiện tại (3.0 điểm)

- Phân tích khiếm khuyết trong thiết kế và cơ chế xử lý dữ liệu của hệ thống hiện tại.
- Chỉ ra sai lầm trong giả định của nhóm phát triển khi xây dựng các endpoint này.

Câu 2: Phân tích kịch bản và phương thức khai thác (3.5 điểm)

- Trình bày cách thức một tác nhân độc hại (hoặc nhân viên thông thường trong nội bộ) có thể khai thác thiết kế trên nhằm thu thập các thông tin bí mật ngoài phạm vi được phân quyền.
- Liệt kê các dữ liệu nhạy cảm có nguy cơ bị lộ lọt và đánh giá tác động an ninh tương ứng đối với tổ chức.

Câu 3: Đề xuất phương án khắc phục (3.5 điểm)

- Đề xuất hướng giải quyết và tư duy thiết kế lại kiến trúc dữ liệu đầu ra nhằm triệt tiêu hoàn toàn rủi ro trên. (Trình bày ý tưởng giải pháp kiến trúc, có thể kèm mô tả luồng xử lý hoặc đoạn mã nguồn minh họa)